ASHAKids — Auditoría del recorrido web

Corte 2026-10-11-01. Fecha 11/10/2026, America/Lima. Responsable: revisión técnica asistida del equipo.

Repositorio: https://github.com/sromansilva/ashakids-platform .

Rama: feat/piero-dev. SHA base auditada: bd8c17d79eb81b098535179f021e3b0adbfdfd11 (V89), más diff de domingos/pruebas de este corte. Cierre V90_Habilitar_Domingos_Agenda_Recorrido_Web; SHA efectivo de publicación en el relevo.

Entorno: Windows, React 18.3.1, Vite 6.4.4, Python 3.14, FastAPI/SQLAlchemy, PostgreSQL 17.6 compartido/TLS; frontend 5174/API 8000. Alcance: diseño web de escritorio, trazado por código, pruebas locales, metadatos READ ONLY y adopción explícita del CHECK dominical. Sin estudio responsive.

Plazo académico registrado:09/10/2026 18:00 America/Lima; este corte es posterior. Sin puntuación de rúbrica.

01. Dictamen ejecutivo

El núcleo tiene contratos reales de cuentas, pacientes, reservas, sesiones, reportes, planes y juegos persistentes. La UI conserva esas operaciones. Esta revisión no ejecutó una nueva cohorte clínica completa: no certifica operación al 100% con correo, Zoom y escrituras reales.

La UI administrativa exige un hijo al crear familia; el tutor añade otros después. La activación es por correo, no DNI como contraseña. Terapia exige cierre con asistencia/reporte/plan; abrir Zoom no cambia esos estados. El guion adjunto sigue las etiquetas y condiciones actuales.

Indicador	Resultado nuevo	Evidencia
Frontend	319 pruebas/27 archivos;25 rutas; tipos/imports/build PASS	HTTP simulado en componentes
Backend	221 PASS,82 SKIP,19 avisos	Unitarias/ASGI; SQL clínico omitido
API local	87 operaciones del contrato; cuatro GET200 y auth/me 401	Runtime real sin login nuevo
BD	33 tablas,241 columnas,137 restricciones,44 FK	Metadatos READ ONLY
Domingo	CHECK 0–6 adoptado;60 turnos conservados	DDL y relectura tras COMMIT
Navegador	Domingo 09:00, publicación explícita	Fixture sintético, escritorio 1274 px
Excluido	Cohorte completa, Zoom/correo reales, carga, responsive	Aceptación operativa pendiente

02. Arquitectura y cambios

React → HTTP/JSON → FastAPI → SQLAlchemy/PostgreSQL se conserva. Sin conexión frontend/BD ni Supabase Auth. agendaService envía disponibilidad; TurnoDatos valida; TurnoSemanal persiste; reservas consultan el día de semana.

AvailabilityEditor añade Domingo; TurnoDatos admite 0–6 y DisponibilidadDatos 60→70 turnos; ORM/SQL de creación incluyen CHECK 0–6; migración 012 cambia sólo esa restricción. Migraciones históricas preservadas. Script de adopción compara destino, datos agregados, restricciones y permisos; transacción/bloqueo breves, rechazo ante regla inesperada. Seleccionar una casilla no publica.

La BD compartida adoptó 012; 60 filas conservadas por conteo/huella dentro de transacción y tras COMMIT, con ACL/RLS/políticas y otras restricciones iguales. Sin usuarios, pacientes, turnos ni citas reales nuevos para pruebas. API local confirma dia máximo 6 y 70 turnos; runtime remoto no certificado.

Modelo físico: identidad/roles/sesiones auth; tutor/paciente/perfil; reserva/sesión/reporte/tratamiento; actividad/objetivo/mundo/nivel/resultado/perfil/logro. schema-after.json contiene nombres/PK/FK exactos.

Inspector completo cargó 32 modelos frente a 33 tablas físicas. Diferencias: mensaje_adjuntos.tamano_bytes Integer vs BIGINT; mundos.nombre_mundo longitud 50 vs 30; objetivos.titulo 150 vs 20. No verifica semántica de defaults ni valores de cada fila. SQLAlchemy avisó de dependencias circulares reservas/sesiones/tratamientos al ordenar metadata: límite del inspector, no consulta fallida.

03. Identidad, altas y pacientes

Operación	Contrato y fuente	Estado observado
Familia ADMIN	adminService.registrarFamilia; FamiliaCrear hijos mínimo 1	Trazado UI/API; alta real no ensayada
Terapeuta ADMIN	admin_cuentas_creacion; clave aleatoria y correo	Trazado; entrega externa no ensayada
Activación pública	auth/create-password y resend-activation; token/hash	Entrada vacía 422 sin cookie
Identidad	auth/me, permiso por recurso	Runtime anónimo 401; pruebas locales
Hijo TUTOR	patientsService.create → POST pacientes	Formulario/contrato examinados; DML real excluido

Clave inicial no equivale a DNI. Guion usa marcadores y procedencia de códigos, sin secretos ni credenciales inventadas. Graphify orienta relaciones; los archivos se leen para confirmar llamadas y reglas.

REC01 — P1, alta: AdminCuentas.handleCrear llama registrarFamilia; FamiliaCrear exige un hijo. Alta individual existe como API distinta, sin entrada en esta pantalla. Aceptación futura: decidir alta de tutor sin hijo explícita y guiar su primer registro, o mantener alta familiar y ajustar narrativa. No retirar validación sólo para igualar una maqueta.

REC02 — P1, formulario de hijo: PadreConfigShowAddChildModal usa Sexo libre y edad aproximada 365,25 días/año; administración ya usa selector y childAge en años cumplidos. El botón comprueba presencia, no todo el rango 3–12 antes de enviar. Aceptación: compartir selector/cálculo, errores cercanos y foco de modal; backend sigue como autoridad.

REC03 — P2, borrador: Guardar niño prepara lista local; Crear cuenta persiste familia. Editar retira el hijo de la lista hasta guardarlo otra vez. Aceptación: distinguir borrador/persistencia, mostrar pendientes y conservar elemento al cancelar edición. Riesgo UX observado en código, no pérdida real confirmada.

04. Citas, atención, plan y juego

Paso	Condición real	Evidencia/límite
Domingo	Terapeuta activado,0–6/hora 8–17,70 únicos	9 unidades nuevas; frontend; CHECK adoptado
Reserva	Hora futura exacta, hasta 90 días, publicada/libre, sin bloqueo	agenda conserva reglas; sin reserva SQL nueva
Introducción	Sin otra pendiente/atendida; no plan previo	BookingDialog/citas.crear_cita; mocks
Zoom	Automático configurado o enlace manual	Código existente; ingreso real no ensayado
Atención	Registrar → iniciar a la hora → reporte → ASISTIO	SessionActions/ClinicalReportEditor; sin cierre real
Plan	Autor, sesión EN_CURSO/FINALIZADA, reporte con contenido	SessionPlan; contrato/pruebas locales
Terapia	Introducción FINALIZADA/ASISTIO, reporte, plan ACTIVO	citas.recorrido; sin continuidad SQL nueva
Juego	Plan ACTIVO con origen en sesión y mundo asignado	juegos.asignados/registrar; mocks
Premios	100 por primer nivel;100 por completar 3; perfil 1+XP//200	Reglas existentes; sin premios reales nuevos

REC04 — P1, cierre: Zoom/asistencia/reporte/plan son acciones separadas. Aceptación: checklist profesional que indique próximo paso y bloqueo; sin cerrar por Zoom ni saltar la hora. Guion ordena los pasos sin cambiar reglas.

REC05 — P1, habilitaciones: juegos dependen del plan; terapia además del cierre introductorio con asistencia/reporte. Plan publicado EN_CURSO puede habilitar juegos antes de terapia. Aceptación: mensajes específicos por estado; si se quisiera unificar, decisión de producto previa. Reglas intactas en este corte.

REC06 — P1, premio invisible: FamilyWorlds muestra mundos y DemoWorldPlayer resultados, pero Centro Familiar infantil no tiene resumen global XP/nivel ni entrada clara a Perfil/Insignias existentes. Aceptación: resumen pequeño y colección desde Mi mundo, con el mismo progreso/ID; sin devolver carga adulta al inicio.

REC07 — P2, controles: BookingDialog/SessionPlan usan selects nativos; alta administrativa usa AccountSelect. Aceptación: control accesible común, revisión clara de niño/profesional/fecha y tokens glass consistentes. Prioridad escritorio; responsive diferido.

Los niveles de mundo son libres, sin desbloqueo obligatorio 1→2→3. Nivel de perfil es otro contador. Perfil nuevo completa un mundo:400 XP, nivel 3; repetir niveles premiados no vuelve a sumar.

05. Contraste con alcance y BD

Capacidad	Estado comprobado por código/documentación	Acción posterior
Altas, hijos, agenda, sesión, reporte/PDF, plan	Contratos/UI presentes; aceptación real completa pendiente	Ejecutar guion y reunir relecturas
Cinco mundos/premios	basica-1 persistente, asignación profesional	Juegos finales y revisión profesional
Mensajes/adjuntos	Servicios/participantes, límite 10MB	Demo autorizada sanitizada
Emociones/ML/dataset	Diferido en plan; tabla no acredita modelo operativo	No presentar reconocimiento real
Reporte/certificado mensual	Pendiente; PDF de sesión no equivale al mensual	Precisar contrato/sección
Configuración	Tarjetas informativas de herramientas	Logo no acredita conexión
RENIEC terapeuta	Visual bloqueado según encargo	Pendiente de integración
Pagos	Excluidos por profesor	Sin cobros ni nuevas tareas

REC08 — P2, documentación: guíasV46 conservan contraseña inicial y conteos históricos. Aceptación: usar este guion como entrada vigente y preservar informes previos etiquetados por corte.

REC09 — P1 técnico, compatibilidad: longitudes de mundos/objetivos podrían rechazar valores admitidos por ORM; tamaño BIGINT de adjuntos es más amplio que Integer. No se reprodujo una escritura fallida. Aceptación: ensayar límites en BD descartable y acordar modelo/migración; sin truncar datos ni ampliar otras tablas en esta revisión.

Actividades/objetivos/resultados ya se usan en juegos básicos; no se consideran ausentes por faltar diseño definitivo/editor avanzado. Se separan faltantes iniciales, extensiones diferidas y diferencias de narrativa/UI.

06. Seguridad y riesgos

Autenticación propia, cookie HttpOnly y permisos por recurso en FastAPI; ocultar botones no autoriza. Prueba anónima verifica endpoints protegidos; excepciones públicas por método/ruta exactos, no prefijo. auth/activate sigue protegido.

Primera suite falló por esperar 401 en create-password público. Se corrigió la expectativa sin cambiar API y añadieron cinco casos públicos vacíos 422 sin cookie y catálogo 200 sin ejercicios/respuestas. No se enviaron correos ni crearon sesiones auth con esos casos inválidos.

DDL dominical conserva permisos: sólo CHECK, sin grants/policies/usuarios. Script no imprime URLs/contraseñas, respaldo privado, destino runtime/propietario coincidente y relectura tras COMMIT.

Riesgos: no declarar correo/Zoom exitosos sin evidencia; juego no equivale a evolución clínica; mantener paciente/plan al cambiar perfil. Metadatos y auth anónima no constituyen pentest ni prueba de aislamiento SQL entre familias.

07. Evidencias y límites

Comando/caso	Resultado nuevo	Evidencia
pytest tests -q	221 PASS,82 SKIP,19 avisos	backend-test-summary.json
test_sunday_availability_unit.py	9 PASS incluidos en 221, sin BD	Fuente de casos
vitest run	319 PASS/27 archivos	frontend-test-summary.json
routing.test.mjs	25 PASS	Resumen frontend
tsc/check-frontend/vite build	PASS;385 fuentes;1935 módulos	Resumen frontend
Impeccable detect	Sin detecciones en AvailabilityEditor	Resumen frontend
Inspector con app.main	READ ONLY;33/241/44 FK,32 modelos,3 diferencias	schema-after.json
audit_readonly	16 SELECT LIMIT0;87 operaciones; GET200/auth 401	runtime-readonly.json
Adopción 012	60 filas/huella/ACL iguales tras COMMIT	sunday-adoption.json
GET OpenAPI	dia máximo 6,70 turnos	live-sunday-contract.json
Navegador fixture	Domingo 09 marcado/publicado, dia 6; sin BD	disponibilidad-web-sintetica.png

Inicialmente faltaba pypdf en el venv: instalado 6.20.0 según rango existente requirements-dev. Primer pase 214 PASS/82 SKIP/1 FAIL en expectativa pública antigua; final 221/82 incluye seis casos nuevos. No sumar ambos pases.82 omitidos requieren otra infraestructura/BD; caso SQL dominical actualizado en test_new_agenda aún requiere base descartable.

Avisos:19 deprecaciones Starlette/httpx/cookies; DEP0205 Node; ciclo de metadata. Sin afirmar su corrección. Inspector previo sólo cargaba 22 modelos; final 32, por eso diferencia final es 3 y no sólo 1. Evidencia schema-before conserva ese alcance anterior.

Rúbrica	Evidencia	Límite
Arquitectura/backend	Capas, OpenAPI87, runtime	Sin E2E externo
Modelo físico/relaciones	33 tablas/241 columnas/137 restricciones/44 FK, CHECK	Sin certificar cada escritura
Seguridad/usuarios/permisos	Auth/ASGI, ACL conservada	Sin pentest/cohorte nueva
Funcional/no funcional	Unitarias/componentes, tipo/build, UI escritorio	Sin carga/responsive

Evidencias nuevas: docs/evidence/audit-2026-10-11-01/. V88/V89 e informes previos son contexto, no pruebas nuevas. No existe una nueva sesión completa real confirmada en este corte.

08. Cierre y siguiente aceptación

Entregables: informe editable/PDF; docs/acceptance/GUION_RECORRIDO_BASE_WEB.md; docs/operations/DISPONIBILIDAD_DOMINGO.md. REC01–REC09 quedan documentados para otra fase. Sólo se resuelve domingo y se actualizan comprobaciones públicas históricas.

Orden: equipo decide alta tutor; frontend unifica hijo/acceso infantil a premios; UX guía cierre/reporte/plan; backend ensaya diferencias de tipos/longitudes en BD descartable; responsable de integración valida activación/Zoom y relecturas clínicas con guion.

Cierre publicado en dev y feat/piero-dev; SHA efectivo en IMPLEMENTATION_PROGRESS. No se declara despliegue remoto por push. Repositorio: https://github.com/sromansilva/ashakids-platform .